

목차 (Table of Contents)

I. Executive Summary

1. 시장 현황 및 Executive Brief
2. 비전 및 핵심 가치 제안
3. 핵심 성과 지표 (KPI)
4. 대상 고객
5. 시스템 아키텍처 및 데이터 흐름
6. 핵심 모듈

II. 기능 명세 (Feature Specifications)

1. Secure Chat (SC)
2. Security & Defense (SD)
3. Compliance (CP)
4. RAG System (RG)
5. AI Quality (QA)
6. Multi-Tenancy (MT)

III. 기술 아키텍처 (Technical Architecture)

1. 33 Docker Containers 구성
2. Backend 마이크로서비스
3. ML 서비스
4. 인프라스트럭처
5. Observability 스택

IV. 경쟁 분석 (Competitive Analysis)

1. 경쟁 구도
2. 기술 비교 매트릭스
3. KYRA 차별화 포인트

V. 가격 정책 (Pricing)

1. 어플라이언스 라인업 (Standard / Advanced / Enterprise)
2. 기능별 비교
3. TCO 비교 분석

VI. 기대 효과 (Expected Benefits)

1. ROI 분석
2. 고객 사례

VII. Agentic AI 보안 (Agentic AI Security)

1. RBAC 기반 에이전트 보호 아키텍처
2. ABAC 기반 속성 제어 및 동적 정책

VIII. 구축 방법론 (Implementation Methodology)

1. Phase 1: 솔루션 기본 도입
2. Phase 2: KITA 맞춤 커스터마이징
3. Phase 3: 운영 안정화 및 이관

I. Executive Summary — 비전 및 핵심 가치

EXECUTIVE BRIEF

McKinsey(2024)에 따르면 Fortune 500 기업의 65%가 생성형 AI 파일럿을 진행 중이며, Gartner 조사에서 AI 도입 기업의 55%가 데이터 프라이버시를 최대 리스크로 선정하였습니다. OWASP LLM Top 10(2025)에서 프롬프트 인젝션이 1위 위협으로 지정되었으며, IBM 보고서 기준 데이터 유출 사고의 평균 피해액은 건당 \$4.88M에 달합니다. AI 도입이 선택이 아닌 필수가 된 시대, 보안 없는 AI는 최대의 리스크입니다. KYRA AI Guardrail은 이 격차를 해소하기 위해 설계된 엔터프라이즈급 AI 보안 플랫폼입니다.

비전

생성형 AI의 안전한 기업 도입을 위한 보안 · 거버넌스 · 컴플라이언스 통합 플랫폼을 제공한다. KYRA AI Guardrail은 프롬프트 인젝션 방어, 데이터 유출 방지(DLP), 컴플라이언스 자동화, 고급 RAG를 하나의 플랫폼에서 통합 관리하여, 기업이 LLM을 안전하고 규제에 부합하게 배포할 수 있도록 지원한다.

핵심 가치 제안

가치	설명	적용 사례
3-Level Prompt Injection Defense	Pattern Matching + ML Classification + Behavioral Analysis 3단계 방어로 프롬프트 인젝션 공격을 실시간 탐지 및 차단	금융사 챗봇에서 "시스템 프롬프트 공개" 공격 자동 차단
Enterprise DLP	PII, 금융정보, 의료정보(PHI), 자격증명(Credentials)을 실시간 탐지·차단하여 민감 데이터 유출 방지	직원이 AI에 고객 주민번호 입력 시 자동 마스킹 처리
Compliance Automation	SOC 2 Type II / GDPR Art.15~34 / HIPAA 규정 준수를 자동화하여 감사 비용 절감 및 규제 대응 가속화	GDPR 정보삭제 요청(DSR) 접수 후 72시간 내 자동 처리
Advanced RAG	11종 Document Connector + Hybrid Search + Cohere Reranking + Citation Verification으로 고품질 AI 응답 생성	법률사무소 판례 검색 시 출처 자동 인용 및 환각 검증

I. Executive Summary — KPI 및 대상 고객

핵심 성과 지표 (KPI)

> 99.5%

INJECTION BLOCK RATE

< 0.1%

FALSE POSITIVE RATE

< 200ms

PROCESSING LATENCY

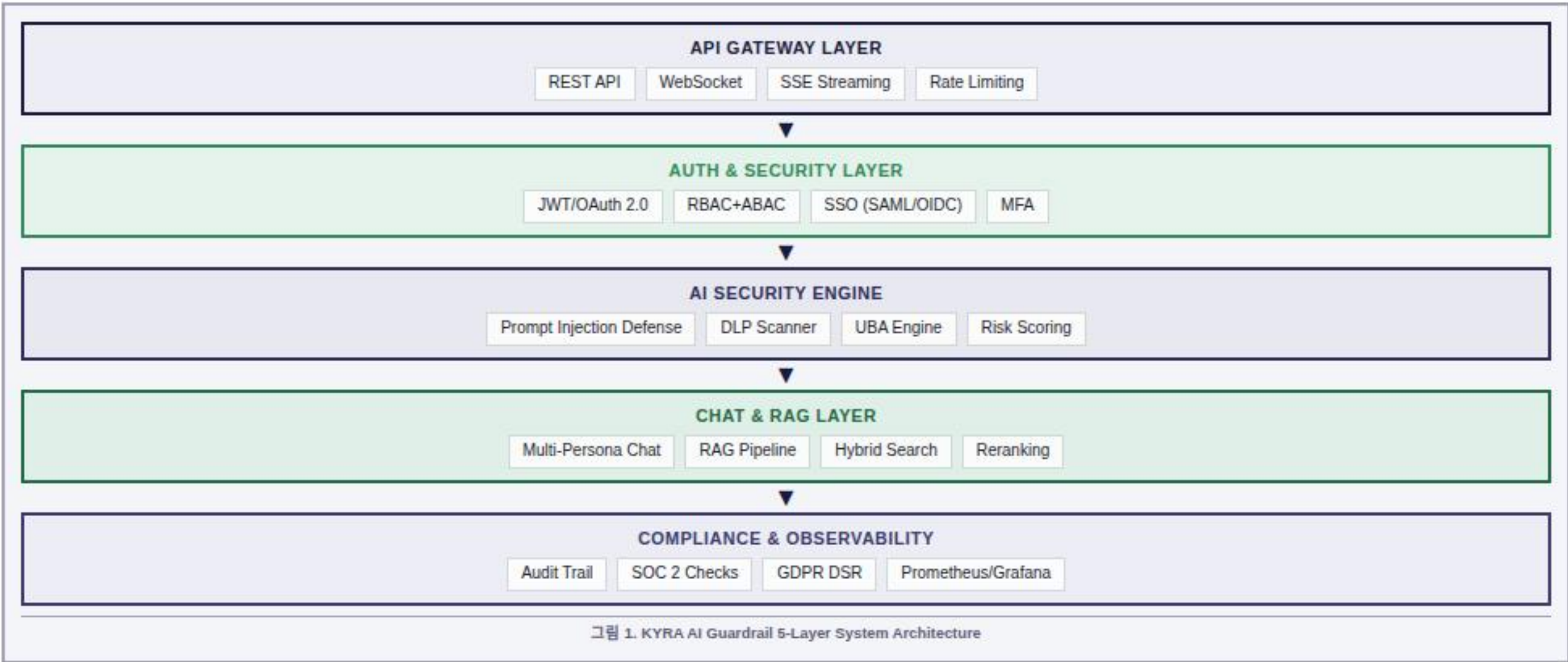
100%

AUDIT COVERAGE

대상 고객

- 금융 기업 — LLM 기반 고객 상담, 문서 분석 시 민감 금융정보 보호 및 규제 준수
- 의료 기관 — AI 진단 보조, 의료 기록 분석 시 PHI 보호 및 HIPAA 컴플라이언스
- 법률 사무소 — 법률 문서 RAG 검색, 의뢰인 비밀 유지 의무 준수
- 공공 기관 — 행정 AI 도입 시 개인정보보호법 준수 및 감사 추적
- 기술 기업 — 내부 AI 도구의 소스코드/API 키 유출 방지 및 프롬프트 보안

시스템 아키텍처



Request Lifecycle (데이터 흐름)



핵심 모듈 (Priority Matrix)

#	카테고리	ID 접두사	기능 수	우선순위
1	Secure Chat	SC	4	● P0
2	Security & Defense	SD	6	● P0
3	Compliance	CP	6	● P0
4	RAG System	RG	5	● P1
5	AI Quality	QA	4	● P1
6	Multi-Tenancy	MT	4	● P0
	합계		29	

설계 원칙: 6개 카테고리, 29개 기능으로 구성된 KYRA AI Guardrail은 보안(Security) · 거버넌스(Governance) · 품질(Quality)을 단일 플랫폼에서 통합 제공합니다. ● P0(핵심)은 Phase 1에서, ● P1(확장)은 Phase 2에서 구현됩니다.

II. 기능 명세 — Secure Chat (SC)

ID	기능명	설명	Input / Output	SLA	적용 사례
SC-01	Multi-Persona AI Chat	12+ AI 페르소나(보안 분석가, 법률 어시스턴트, 코드 리뷰어 등) 선택 기반 컨텍스트 특화 대화	사용자 메시지 / 페르소나별 응답	< 500ms TTFT	법무팀이 '법률 어시스턴트' 페르소나로 계약서 검토 질의
SC-02	Conversation Branching & Version Control	대화 트리의 특정 지점에서 분기(Branch) 생성, 버전 비교 및 이전 상태 복원	분기 지점 선택 / 트리 구조 대화	< 100ms	보안팀이 동일 인시던트를 다른 분석 관 점으로 분기 탐색
SC-03	SSE Real-time Streaming	Server-Sent Events 기반 실시간 토큰 스트리밍, 중단/재개 지원	프롬프트 / 스트림 토큰	< 100ms TTFT	긴 보고서 생성 중 실시간으로 진행 상황 확인 및 중단
SC-04	Message Bookmark & Citation	중요 메시지 북마크, AI 응답의 출처(Citation) 추적 및 검증	메시지 ID / 출처 메타데이터	< 50ms	감사팀이 AI 답변 출처를 원문 문서와 대 조 검증

II. 기능 명세 — Security & Defense (SD)

ID	기능명	설명	Input / Output	SLA	적용 사례
SD-01	3-Level Prompt Injection Defense	L1: Regex/Pattern (SQL Injection, Jailbreak) → L2: ML Classifier (Fine-tuned BERT, 99.5%) → L3: Behavioral Analysis (세션별 이상 패턴)	프롬프트 / 차단 여부 + 위험 스코어	< 50ms	외부 사용자가 "Ignore previous instructions" 공격 시도 시 L1에서 즉시 차단
SD-02	DLP Pattern Scanning	PII (주민번호, 전화번호, 이메일), 금융정보 (카드/계좌번호), 자격증명 (API Key, Password) 실시간 탐지 및 마스킹/차단	텍스트 / 탐지 결과 + 마스킹	< 30ms	상담원이 AI에 고객 카드번호 입력 시 자동 마스킹 (1234-****-****-5678)
SD-03	DLP Contextual Whitelisting	비즈니스 컨텍스트에 따른 동적 허용 목록 관리 (예: 재무팀의 금융정보 접근 허용)	컨텍스트 규칙 / 허용/차단	< 10ms	재무팀은 금액 정보 접근 허용, 마케팅팀은 차단
SD-04	User Behavior Analytics (UBA)	사용자별 쿼리 패턴, 접속 시간, 데이터 접근 빈도 분석을 통한 내부 위협 탐지	활동 로그 / 이상 행위 알림	실시간	심야 시간 대량 데이터 추출 시도 탐지 및 관리자 알림
SD-05	Risk Scoring & Auto-MFA	다차원 리스크 점수 산출 (IP, 디바이스, 행동 패턴) 및 고위험 시 자동 MFA 트리거	세션 컨텍스트 / 리스크 점수	< 100ms	해외 VPN 접속 + 고위험 쿼리 시 자동 추가 인증 요구
SD-06	PHI Detection (9 Safe Harbor)	HIPAA Safe Harbor 기준 9가지 PHI 패턴 (이름, 생년월일, 의료기록번호, SSN 등) 자동 탐지 및 비식별화	텍스트 / PHI 탐지 + 비식별화	< 30ms	의료 AI 챗봇에서 환자 이름/생년월일 자동 비식별화

II. 기능 명세 — Compliance (CP)

ID	기능명	설명	Input / Output	SLA	적용 사례
CP-01	SOC 2 Type II Control Checks	보안, 가용성, 처리 무결성, 기밀성, 프라이버시, 변경관리 6개 영역 자동 통제 점검	시스템 상태 / 8/17 통제 결과	매일 자동	매일 00시 자동 SOC 2 점검 수행 및 미충족 항목 즉시 알림
CP-02	GDPR DSR Automation	Art.15 접근권, Art.17 삭제권, Art.18 처리제한권, Art.20 이동권에 대한 DSR 자동 처리	DSR 요청 / 처리 완료 보고서	< 72h	EU 고객 "내 데이터 삭제" 요청 시 자동 삭제 및 보고서 생성
CP-03	GDPR Breach Notification (72h)	개인정보 침해 발생 시 72시간 내 감독기관 통보 워크플로우 자동화 (Art.33)	침해 이벤트 / 통보 타임라인	72h 내 완료	데이터 유출 탐지 후 DPO 알림 → 감독기관 통보 자동화
CP-04	HIPAA PHI Protection	PHI 데이터의 암호화(AES-256), 접근 통제, 감사 로그 자동 관리	PHI 데이터 / 보호 상태 대시보드	실시간	의료기관 EMR 연동 시 PHI 전구간 AES-256 암호화 적용
CP-05	Immutable Audit Trail (SHA-256)	모든 사용자 활동, AI 응답, 관리 작업에 대한 SHA-256 해시 체인 기반 변경 불가 감사 로그	시스템 이벤트 / 해시 체인 로그	실시간	외부 감사 시 변경 불가능한 로그 체인으로 무결성 입증
CP-06	Processing Register (Art.30)	GDPR Art.30 요구사항에 따른 처리 활동 기록부 자동 생성 및 관리	처리 활동 / Art.30 레지스터	실시간 갱신	신규 AI 서비스 추가 시 처리 활동 기록부 자동 업데이트

II. 기능 명세 — RAG System (RG)

ID	기능명	설명	Input / Output	SLA	적용 사례
RG-01	11 Document Connectors	PDF, DOCX, PPTX, XLSX, CSV, TXT, Markdown, HTML, Confluence, SharePoint, Google Drive 등 11종 문서 소스 연동	문서 파일/URL / 벡터 임베딩	< 5min/100p	사내 Confluence 위키 전체를 자동 인덱싱하여 AI 검색 지원
RG-02	Hybrid Vector + Full-Text Search	Milvus 벡터 검색 + OpenSearch 전문 검색을 결합한 하이브리드 검색으로 높은 재현율과 정밀도 달성	검색 쿼리 / Top-K 결과	< 200ms	"2024년 4분기 매출 보고서" 검색 시 의미+키워드 결합 정밀 검색
RG-03	Cohere Reranking	1차 검색 결과를 Cohere Reranker 모델로 재순위화하여 관련도 상위 문서를 정밀 선별	Top-K 결과 / 재순위화 결과	< 300ms	100건 후보 문서에서 질문과 가장 관련 높은 상위 5건 자동 선별
RG-04	Self-Query RAG	사용자 질문에서 메타데이터 필터를 자동 추출하여 구조화된 검색 조건 생성	자연어 질문 / 구조화 쿼리	< 500ms	"김 부장이 작성한 작년 보안 감사 보고서" - 저자+날짜+유형 필터 자동 생성
RG-05	Citation Verification	AI 응답에 포함된 인용의 정확성을 원문과 대조 검증하여 환각 (Hallucination) 방지	AI 응답 + 출처 / 검증 결과	< 1s	AI가 인용한 법률 조항을 원문과 자동 대조, 불일치 시 경고 표시

II. 기능 명세 — AI Quality (QA) & Multi-Tenancy (MT)

AI Quality (QA)

ID	기능명	설명	적용 사례
QA-01	6-Dimension Quality Scoring	정확성, 관련성, 완전성, 일관성, 유용성, 안전성 6차원 품질 점수	고객 상담 AI 응답의 품질을 6차원으로 실시간 모니터링
QA-02	Semantic Cache	의미적 유사 질문 캐싱 (Cosine > 0.95), < 50ms hit	FAQ 질문 중복 호출 시 캐시로 LLM 비용 70% 절감
QA-03	Hallucination Detection	NLI 모델로 AI 응답과 원문 정합성 검증	계약서 분석 AI가 존재하지 않는 조항 인용 시 탐지 차단
QA-04	Sentiment Analysis	감성 분석으로 부적절한 톤/감정 탐지	고객 응대 AI가 공격적 톤으로 응답 시 자동 필터링

Multi-Tenancy (MT)

ID	기능명	설명	적용 사례
MT-01	Row-Level Security (RLS)	PostgreSQL RLS 기반 테넌트 간 완전 데이터 격리	A사 데이터가 B사 관리자에게 절대 노출되지 않음을 보장
MT-02	RBAC + ABAC	역할+속성 기반 하이브리드 접근 제어	부서/직급/프로젝트별 AI 기능 접근 권한 세분화
MT-03	SSO (SAML/OIDC/LDAP)	기업 싱글 사인온 통합	사내 AD 계정으로 별도 로그인 없이 AI 플랫폼 접근
MT-04	SCIM Provisioning	SCIM 2.0 사용자/그룹 자동 프로비저닝	HR 시스템 퇴사 처리 시 AI 플랫폼 계정 자동 비활성화

IV. 경쟁 분석 (Competitive Analysis)

경쟁 구도



핵심 차별화

KYRA AI Guardrail은 경쟁사 대비:

- (1) 3-Level Prompt Injection Defense — 유일한 3단계 방어
- (2) 포괄적 DLP — PII + Financial + PHI + Credentials
- (3) 통합 컴플라이언스 — SOC 2 / GDPR / HIPAA
- (4) 고급 RAG + 환각 탐지 — 11 Connectors + NLI 검증

단일 플랫폼에서 제공하는 유일한 솔루션입니다.

KYRA 차별화 포인트

KYRA ONLY — 경쟁사에 없는 고유 강점

- 1 "보안+품질+거버넌스" 올인원 플랫폼**
경쟁사는 보안 또는 모니터링 중 하나만 제공. KYRA는 프롬프트 방어부터 컴플라이언스까지 단일 배포로 해결하여 도구 분산(Tool Sprawl)을 제거합니다.
- 2 On-Premise 완전 자주권 (Air-Gap 지원)**
33개 컨테이너 전체를 고객 폐쇄망에 배포 가능. 데이터가 외부로 한 바이트도 나가지 않아 금융·공공·국방 환경에서 즉시 도입 가능합니다.
- 3 3-Level Behavioral Defense + UBA 연계**
업계 유일의 Pattern → ML → Behavioral 3단계 방어에 사용자 행동 분석(UBA)을 결합하여 단발성 공격뿐 아니라 지속적 내부 위협까지 탐지합니다.

IV. 기술 비교 매트릭스

기능	Lakera Guard	Protect AI	Arthur AI	CalypsoAI	KYRA AI Guardrail
Prompt Injection Defense	Core (1-Level)	Basic	No	ML-based	3-Level (Pattern+ML+Behavioral)
DLP / Data Protection	Basic PII	No	No	Limited	PII+Financial+PHI+Credentials
SOC 2 Compliance	No	No	Partial	Partial	12/17 Control Checks
GDPR Automation	No	No	No	Basic	DSR + Breach + Art.30
HIPAA PHI Protection	No	No	No	No	9 Safe Harbor Patterns
RAG System	No	No	No	Basic	11 Connectors + Hybrid + Rerank
Hallucination Detection	No	No	Core	Basic	NLI + Citation Verify
Multi-Tenancy (RLS)	No	No	Basic	Basic	PostgreSQL RLS + RBAC/ABAC
SSO Enterprise	OIDC only	No	Yes	Yes	SAML 2.0 + OIDC + LDAP
Immutable Audit Trail	No	No	Basic	Basic	SHA-256 Hash Chain

V. 가격 정책 — 어플라이언스 모델 (Pricing)

항목	Standard	Advanced	Enterprise
형태	1U 랙마운트	2U 랙마운트	2U 랙마운트 (HA)
도입 가격	₩80,000,000~	₩250,000,000~	₩500,000,000~ (별도 견적)
연간 유지보수	도입가 15%	도입가 15%	도입가 12%
사용자 수	100명	500명	Unlimited
스토리지	1TB SSD	4TB NVMe	16TB+ NVMe (RAID)
GPU	-	A30 × 1	A100/H100 × 2+
Prompt Injection	Level 1+2	Level 1+2+3 (Full)	Full + Custom Rules
DLP	PII + Financial	Full	Full + Custom
RAG / SSO / Compliance	5 Conn. / SAML+OIDC / SOC2+GDPR	11 Conn. / Full SSO / Full	11+ Custom / Full+SCIM / Full+Custom
고가용성 (HA)	단일	Active-Standby	Active-Active
SLA	99.5%	99.9%	99.99%

V. TCO 비교 분석 — 3년 총 소유 비용

AI 보안 솔루션의 도입 방식별 3년 총 소유 비용(TCO)을 비교합니다. KYRA AI Guardrail 어플라이언스 모델은 SaaS 대비 데이터 주권을 보장하면서, 자체 구축 대비 70% 이상의 비용 절감을 실현합니다.

TCO 비교표 (500명 규모, 3년 기준)

비용 항목	자체 구축 (Build)	SaaS 구독	KYRA 어플라이언스 (Advanced)
초기 도입비	₩500,000,000+ (개발팀 6~12개월)	₩0 (구독 방식)	₩250,000,000 (턴키 배포)
연간 운영비	₩200,000,000+ (인건비 5명 + 인프라)	₩180,000,000 (₩30K/user/월 × 500명)	₩18,000,000 (유지보수 15%)
3년 총비용	₩1,100,000,000+	₩540,000,000	₩174,000,000
데이터 주권	완전 통제	벤더 클라우드	완전 통제
도입 소요 기간	6~12개월	1~2주	2~4주
커스터마이징	무제한 (자체)	제한적	정책/규칙 커스텀
3년 대비 절감율	기준선	51% 절감	84% 절감

핵심 인사이트: 자체 구축은 고속렌 보안 엔지니어 채용 및 지속적인 ML 모델 업데이트 비용이 가장 큰 부담입니다. SaaS는 데이터 주권 이슈로 금융·공공 분야에서 도입이 제한됩니다. KYRA 어플라이언스는 데이터 주권 + 비용 효율 두 가지를 동시에 달성하는 유일한 선택입니다.

VI. 기대 효과 — ROI 분석

항목	현재 (수동 관리)	KYRA AI Guardrail 도입 후	개선 효과
보안 사고 대응 시간	평균 4~8시간	< 30분 (자동 탐지·차단)	> 90% 단축
컴플라이언스 감사 비용	연 \$80K~\$200K	연 \$15K~\$40K	70~80% 절감
데이터 유출 사고	연 2~5건 (피해 \$200K)	연 0~1건	> 80% 감소
AI 응답 품질 관리	수동 샘플링 (5%)	자동 전수 검사 (100%)	20x 향상
보안팀 운영 효율	FTE 3~5명 전담	FTE 1명 + 자동화	60~80% 절감
규제 위반 리스크	GDPR 20M EUR, HIPAA \$1.5M	사전 예방 리스크 최소화	> 95% 감소

3~6개월

투자 회수 기간 (PAYBACK)

300%+

3년 ROI

> 80%

운영 비용 절감

100%

규제 준수율

VII. AI Agent 사례 1 — 제조기업: 공급망 리스크 관리

산업	제조 (반도체 장비), 협력사 1,700+개
도입 배경	공급망 리스크(지정학, 자연재해) 대응 지연
배포 방식	프라이빗 클라우드 (Kubernetes)
도입 기간	POC 6주 → 전사 적용 4개월

Agent	역할	자율성
공급망 모니터링	글로벌 뉴스, 지정학, 재해 실시간 감시	Level 4
협력사 리스크 평가	재무/운영/규제 리스크 종합 스코어링	Level 3
대안 소싱	대체 공급처 탐색 및 비교 분석	Level 3
컴플라이언스	수출 규제, 제재 대상 준수 점검	Level 2

4시간

리스크 탐지 (72시간 →)

89%

공급 중단 사전 예측

¥18B

연간 리스크 비용 절감

60%

대응 계획 수립 시간 단축

핵심 성과: 대만 지진 발생 시 4시간 내 영향 분석 + 대체 공급처 3곳 경영진 보고. 기존 72시간 대비 대응 속도 18배 향상.

VII. Agentic AI 보호: RBAC 기반 역할 제어

에이전트 요청 처리 흐름

- 1□ 요청 수신 — Agent가 문서 읽기, 도구 호출
- 2□ 역할 추출 — Gateway에서 JWT 토큰으로 역할 확인
- 3□ 정책 평가 — OPA에서 role:resource 권한 검사
- 4□ 의사결정 — 허용(✓) / 거부(✗) + 감사로그

정책 평가 예시:

```
role: power_user
resource: document:confidential
action: read
→ DENY (로그 기록)
```

역할	공개	내부	기밀	Tool호출
Admin	✓	✓	✓	전체
Manager	✓	✓	✓	제한
Power User	✓	✓	✗	지정
User	✓	✓	✗	읽기
Viewer	✓	✗	✗	없음

<5ms

정책 적용 지연

100%

실시간 역할 반영

0

권한 위반 (감시)

VII. Agentic AI 보호: ABAC 기반 속성 제어

속성 기반 접근 제어 흐름:

[Agent 요청] → [속성 추출: doc.classification, user.role, user.tenant_id, action] → [OPA ABAC 정책] → [ALLOW: 비식별화 + 응답] / [DENY: 차단 + 감사로그]

ABAC 정책 속성 (Attributes)

doc.classification	public internal confidential restricted
user.role	admin manager user viewer
user.tenant_id	기업별 데이터 격리
agent.action	read write tool_call export
context.time	시간대별 접근 제한 (옵션)

동적 정책 예

restricted 문서는 admin만 읽기 가능.
읽기 시 PII 자동 마스킹 처리.

관리 콘솔 — Access Policies

역할 × 문서 분류등급 권한 매트릭스
(✓/✗ 체크박스로 실시간 정책 설정)

Access Policies — Role × Classification Matrix

Role / Classification	Public	Internal	Confidential	Restricted
Admin	☒	☒	☒	☒
Manager	☒	☒	☒	☐
Power User	☒	☒	☐	☐
User	☒	☒	☐	☐
Viewer	☒	☐	☐	☐

정책

세분화된 제어

100%

감사 로깅

VIII. 구축 방법론: 솔루션 + 커스터마이징 병행

⚡ Phase 1

솔루션 기본 도입

기간: 1~2개월

- Docker Compose 배포
(33개 컨테이너)
- RBAC/ABAC 정책 활성화
- RAG 시스템 연동
(Milvus + MinIO)
- JWT 인증 + Multi-Tenancy

□ Phase 2

KITA 맞춤 커스터마이징

기간: 3~5개월

- 무역 도메인 RAG 학습
- PII 탐지 규칙 확대
(통관번호, 사업자번호, 계좌)
- Agent Tool 권한 정책 설계
- 대시보드 커스터마이징

□ Phase 3

운영 안정화 + 이관

기간: 6개월~

- 성능 튜닝
(Latency <200ms, Block Rate >99.5%)
- 운영 매뉴얼 작성
- 보안 정책서 작성
- KT DS 운영팀 기술 이전

□ 상주 지원 모델

Phase 2 커스터마이징 기간 중 개발자 상주 지원 가능 (요청 시 협의)

→ 빠른 요구사항 반영, 실시간 기술 지원, 지식 이전 가속화

6개월

구축 기간

100%

맞춤화

∞

지원 준비

✓

이관 완료



KYRA AI Guardrail

Secure AI. Empower Enterprise.

s e e k e r s l a b . c o m